

AI GOVERNANCE DECISION MEMO

Disposition of Two High-Risk AI Systems and Establishment of an AI Governance Program

To: Executive Leadership Team | From: GRC Lead, with General Counsel and CISO | Date: 2026-08-05

Sample GRC portfolio artifact — fictional company. Not legal advice.

1. Decision Required

Leadership is asked to make three decisions by 30 September 2026:

1. Disposition of ClaimDesk Adjudication Assist (AI-001), which is operating for three EU-based client plans as an unassessed high-risk AI system.
2. Disposition of the Recruiting Resume Screener pilot (AI-004), a third-party high-risk system for which the vendor will not provide bias audit results.
3. Establishment of an AI Governance Committee and adoption of an AI policy, which is the root-cause remediation for how the first two situations arose.

This memo lays out the situation, the options considered, and a recommendation for each. It is deliberately short. The supporting analysis is in the AI System Inventory, the AI Risk Assessment, and the AI Governance Control Crosswalk.

2. How We Got Here

Rockledge deployed nine AI systems over roughly thirty months. None went through a governance review, because no governance function existed. Each business unit made a locally reasonable decision; the aggregate is that the company now operates two systems that meet the EU AI Act's definition of high-risk — one in production, one in pilot — with none of the documentation, testing, or oversight design that classification requires.

This is not unusual. It is the modal state of mid-size organizations in 2026. It is also not sustainable, because the regulatory calendar has started to move and because the harms these systems can cause — discriminatory benefit denials, discriminatory hiring shortlists — are real regardless of what any regulator does.

On the timeline — what changed last week

The Digital Omnibus on AI (Regulation (EU) 2026/1744) was published in the Official Journal on 24 July 2026 and entered into force on 27 July 2026, six days before the AI Act's original high-risk deadline. Standalone Annex III high-risk obligations now apply from 2 December 2027; high-risk AI embedded in regulated products from 2 August 2028.

That is sixteen additional months, and it materially changes the cost of Option A below. It should not change our posture, for three reasons.

- The deferral is selective. Article 50 transparency duties were expressly NOT deferred and applied from 2 August 2026. Our member chatbot does not meet them today. That obligation is live and we are already past it — it is the only item in this memo with a deadline in the past.
- Deadlines govern enforcement, not harm. AIR-001 is the risk that ClaimDesk encodes historical bias into denial recommendations. It has no compliance date. The model either discriminates or it does not, and we currently cannot say which. A member denied benefits in 2026 is not helped by a 2027 deadline.
- Sixteen months is one procurement cycle plus one remediation cycle. Organizations that read 'deferred' as 'resolved' will arrive at December 2027 in exactly the position they are in now. The runway is the opportunity, not the reprieve.

3. Decision 1 — ClaimDesk Adjudication Assist (AI-001)

What it does	Recommends approve / deny / pend on benefit claims. Adjuster confirms each recommendation.
Classification	CONTESTED. Annex III(5)(a) covers essential public assistance benefits administered by public authorities — we are a private administrator. Annex III(5)(c) covers risk assessment and pricing for life and health insurance — this is claims adjudication, not pricing. Counsel determination required. Treated as high-risk pending that answer.
Current governance	None. No fairness testing, no drift monitoring, no technical documentation, no conformity assessment, no EU registration.
Key finding	Adjuster override rate is 3%. At that rate the human is ratifying, not reviewing. The 'human-in-the-loop' control that everyone assumed was there is nominal.
Residual risk after planned controls	Critical (AIR-004) if high-risk; High if not. Either way the fairness and explainability gaps stand on their own merits.

Because classification is unsettled, the options below are framed to work under either outcome. That is deliberate: we should not defer action for three months waiting for a legal answer that changes the deadline but not the underlying exposure.

Options

Option	Description	Assessment
A	Build the conformity path: full risk management system, data governance, fairness testing, technical documentation, oversight redesign, EU registration. Continue serving all plans.	Right long-term answer if the EU book is strategic AND counsel confirms high-risk status. Cost is high (est. 9–12 months). The Omnibus deferral to 2 Dec 2027 makes this comfortably achievable on the calendar, which was not true a month ago. Premature if classification is not yet settled.
B	Carve the three EU plans out to manual adjudication immediately. Continue ClaimDesk for US plans while building governance controls at a sustainable pace. Re-onboard EU plans to ClaimDesk once conformity is achieved.	Removes regulatory exposure regardless of how classification resolves. Costs ~2.5 FTE for EU plans (roughly 4% of claim volume). With the deferral now law, the case for this is weaker than it was — there is time to determine classification first rather than absorbing cost pre-emptively.
C	Exit the EU book.	Not proportionate. Three plans; the exposure is manageable through B. Reserved as fallback if conformity cost proves prohibitive.
D	Do nothing pending final Digital Omnibus text.	Superseded. The Omnibus is adopted; there is no longer a pending text to wait on. The live question is classification, not the calendar.

Recommendation: Obtain the classification determination; begin fairness work now; hold Option B in reserve

Instruct counsel to determine Annex III applicability by 30 September 2026. In parallel, and without waiting for that answer, begin fairness testing (AIR-001), explainability (AIR-002), and drift monitoring (AIR-003) on the US deployment. That work is required on its merits, is the bulk of any conformity path, and is the only way to answer whether the system is currently causing harm.

The reasoning has two parts. First, sequencing: fairness testing is required whether or not the system is high-risk, and its results determine whether Option A is even viable — if the model needs rebuilding, a conformity package built around it is wasted work. Do the thing that informs the decision before making the decision.

Second, proportionality. Before 27 July, carving out the EU plans immediately was the right call because the deadline was six days away and the deferral was speculative. That urgency is gone. Absorbing 2.5 FTE of manual adjudication cost now, before we know whether the classification even applies, would be paying an insurance premium against a risk we have sixteen months to assess. Option B stays on the table as the fallback if counsel confirms high-risk status and fairness testing comes back poorly.

4. Decision 2 — Recruiting Resume Screener (AI-004)

What it does	Ranks applicants; recruiter reviews the top 20.
Why it is high-risk	Employment (Annex III). Dublin recruiting creates EU exposure; NYC roles trigger Local Law 144's independent bias audit requirement.
Current governance	None. Vendor declines to disclose training data or provide bias audit results.
Key finding	Candidates ranked 21st and below are never seen by a human. For those applicants, this is a fully automated adverse decision, whatever the vendor's marketing says about 'assistive' ranking.
Residual risk after planned controls	Critical (AIR-005) — because the controls we would need depend on vendor cooperation we do not have.

Recommendation: Pause the pilot. Condition resumption on the vendor.

Pause immediately — this is a pilot, so pausing costs little. Notify the vendor in writing that resumption requires (a) a third-party bias audit report meeting NYC Local Law 144 standards, and (b) transparency documentation sufficient for EU AI Act Article 13. Give them 60 days. If they can't or won't provide it, terminate and evaluate alternatives that can. Note that unlike ClaimDesk, this classification is not in doubt — Annex III(4)(a) names recruitment and candidate evaluation explicitly — and NYC Local Law 144 applies on its own timeline with no dependency on the EU deferral.

This is the easy decision and it is worth naming why. A vendor that will not show you bias audit results for a hiring tool is telling you something. The organization should not need a governance committee to act on that signal, but the fact that the pilot ran for four months without anyone acting on it is precisely why the committee is needed.

5. Decision 3 — Establish AI Governance

Both situations above share a root cause: no one was accountable for asking whether an AI system should exist before it did. The remediation is structural, not technical.

Recommendation

- Charter an AI Governance Committee within 30 days. Chair: General Counsel. Members: CISO, CIO, Chief Actuary, VP People, Head of Compliance, GRC Lead as secretariat. Quarterly cadence; ad hoc for new system approval.
- Adopt an AI Policy covering acceptable use, mandatory intake review for new AI systems, prohibition on consumer AI tools for sensitive data, and system-owner accountability. Attestation for all staff.
- Assign a named business owner to every system in the inventory. Owners are accountable for their system's risk assessment currency and control implementation.
- Adopt NIST AI RMF as the operating method and ISO/IEC 42001 as the target management-system standard. Do not pursue 42001 certification in year one; use its structure to build the program so certification is available later without rework.

- Fund a fairness-testing capability — either a data-science hire with the skill set or a retained third party. Two of the three critical risks depend on it.

This is roughly one senior hire and a modest tooling budget. It is small relative to the exposure it addresses, and smaller than the cost of the first regulatory inquiry or discrimination claim.

6. What This Memo Does Not Recommend

It does not recommend halting AI adoption. Six of nine systems in the inventory are appropriately governed or trivially fixable, and several — document OCR, actuarial forecasting, marketing drafting — deliver clear value at low risk. The point of governance is to make it possible to say yes with confidence, not to say no by default. An organization that responds to this memo by freezing AI will have learned the wrong lesson.

7. Summary of Asks

#	Ask	Owner	By
1	Instruct counsel on ClaimDesk Annex III determination; fund fairness/explainability/drift work to begin immediately; hold EU carve-out in reserve	VP Claims Ops + GC	2026-09-30
2	Approve pause of Resume Screener pilot and vendor conditions for resumption	VP People	2026-08-15
3	Charter AI Governance Committee; adopt AI Policy; assign system owners	GC	2026-08-31
4	Deploy chatbot AI disclosure — Art. 50 obligation already past deadline	Dir. Member Services	2026-08-15
5	Fund fairness-testing capability (hire or retained)	CIO / CFO	2026-09-30

8. Sources and Caveats

Analysis draws on NIST AI RMF 1.0 and the Generative AI Profile (AI 600-1), ISO/IEC 42001:2023, the EU AI Act (Regulation (EU) 2024/1689) as amended by the Digital Omnibus on AI (Regulation (EU) 2026/1744, published in the Official Journal 24 July 2026, in force 27 July 2026), and NYC Local Law 144. This is a portfolio artifact for a fictional company; regulatory citations are for demonstration and would require verification by counsel before reliance in any real decision. Nothing here creates or claims legal privilege.